تقرير صلاحيات مسؤول النظام

Nov 7, 2026 · @zainab hussein

نظرة عامة

يملك مسؤول النظام (`systemAdmin`) في الإعداد الافتراضي **69 صلاحية من أصل 177**، وينفرد وحده بـ **15 صلاحية** كلها إعدادات وتشغيل. الدور مصمم لإدارة الإعدادات والأدوار والأجهزة دون الوصول إلى البيانات الحساسة: لا شكاوى، ولا مالية، ولا ملفات الموظفين الكاملة.

- **المصدر في الكود:** `HrPermissions.DefaultRoles` في `src/HR_Mangment2.Domain.Shared/Permissions/HrPermissions.cs` ، ويُزرع عند كل ترحيل عبر `HrTenantBootstrapper` .
- **الحساب الأول:** `sysadmin` ، ينشأ بكلمة سر مؤقتة يجب تغييرها عند أول دخول، ويحمل دوري `employee` و `systemAdmin` .
- **موقعه الإداري:** المدير الأعلى لمديري الأقسام، ويرتبط هو بالمدير التنفيذي.
- **حساب `admin` الأصلي في ABP:** معطّل تلقائيًا، ودوره `admin` مخفي من شاشة الأدوار، لأن أعضاءه يستطيعون تعيين أي دور.

حسب وثيقة المتطلبات (القسم 5.18) يدير مسؤول النظام: الأدوار والصلاحيات العادية، طريقة الحضور، أنواع الطلبات، أنواع الإجازات الأخرى، مهل الشكاوى، مدة تنبيه العقد، مواعيد التذكير والتصعيد، الأجهزة، ومعايير التقييم.

آلية المصادقة والتحقق

كل طلب يمر بثلاث طبقات: حاجز الحساب، ثم فحص الصلاحية، ثم قواعد العمل داخل الخدمة.

1. **حاجز الحساب** (`AccountAccessEvaluator`): يُحسب من قاعدة البيانات في كل طلب، لا من الرمز. يمنع العمل حتى تغيير كلمة السر المؤقتة، ثم حتى تفعيل التحقق بخطوتين.
2. **التحقق بخطوتين إلزامي** لمسؤول النظام (`HrRoles.MfaRequired`)، كما لمدير الموارد والمدير التنفيذي والمحاسب. الرد عند عدم التفعيل: 403 `Hr:Identity:MfaEnrollmentRequired` .
3. **فحص الصلاحية**: `[Authorize(HrPermissions...)]` على كل دالة خدمة، والصلاحيات معرّفة في `HrPermissionDefinitionProvider` ومجمّعة حسب أول مقطعين من الاسم (مثل `Hr.Settings`).
4. **قواعد العمل**: فحوص داخل الخدمة لا تتجاوزها أي صلاحية، مثل منع تعديل أدوار النفس وحماية آخر مسؤول نظام (التفاصيل في قسم الملاحظات الأمنية).

الصلاحيات المحمية (`ProtectedPermissions`): تُخفى من شاشة الصلاحيات ويُرفض منحها، حتى لمسؤول النظام:

رمز الخطأ	السبب	النمط
`ProtectedPermissionNotGrantable`	سرية الشكاوى	`Hr.Complaint*`
`FinancialPermissionNotGrantable`	فصل المالية	`Hr.Finance*` لمدير القسم أو مسؤول المخزن
`ProtectedPermission`	البيانات المالية	`Hr.Finance*` لأي دور آخر
`ProtectedPermission`	منع تصعيد الصلاحيات	`Hr.Identity.*`
`ProtectedPermission`	ملاحظات التقييم الداخلية	`Hr.Evaluations.InternalNote.*`، `Hr.Evaluations.HrRead`
`ProtectedPermission`	تقارير المراجعة والإنذارات	`Hr.Reports.Review`، `Hr.Warning.Read`

الصلاحيات التفصيلية حسب الوحدة

الصلاحيات الـ 69 موزعة على 15 وحدة. عمود "حصرية" يعني أن مسؤول النظام هو الدور الوحيد الذي يحملها في الإعداد الافتراضي.

العدد	صلاحيات مشتركة مع أدوار أخرى	صلاحيات حصرية لمسؤول النظام	الوحدة
6	قراءة الإعدادات (Read) مع مدير الموارد	مهل الشكاوى (Complaints)، العقود (Contracts)، المالية (Finance)، الإجازة الزمنية (HourlyLeave)، التذكيرات (Reminders)	الإعدادات `Hr.Settings`
9	قراءة الأدوار، قراءة الحسابات والبحث فيها، إعادة ضبط التحقق بخطوتين (ResetMfa)، تعيين أدوار المستخدم (SetRoles)	إدارة الصلاحيات (Permission.Manage)، إدارة الأدوار (Role.Manage)، تفاصيل الدور (Role.ReadDetail)	الهوية والحسابات `Hr.Identity`

العدد	صلاحيات مشتركة مع أدوار أخرى	صلاحيات حصرية لمسؤول النظام	الوحدة
11	عرض الأجهزة، ربط الأجهزة بالموظفين، عرض الإعدادات، بصمة GPS، تصحيح بصمته وعرض التصحيحات، حضوره الشخصي وتفاصيل اليوم	إدارة أجهزة البصمة، السياج الجغرافي (GeoFence)، إعدادات الحضور	الحضور `Hr.Attendance`
8	عرض الأرصدة والسجلات، إنشاء طلب إجازة وعرضه، رصيده وسجله الشخصي	إدارة أنواع الإجازات الأخرى (OtherType.Manage)	الإجازات `Hr.Leave`
9	البريد الوارد (Inbox)، الموافقة (Decide) والرفض (Reject)، إنشاء وإلغاء وعرض الطلبات، عرض الأنواع	إدارة أنواع الطلبات (Type.Manage)	الطلبات `Hr.Request`
2	—	إدارة المعايير (Criteria.Manage)، إدارة التقديرات (Grades.Manage)	التقييم `Hr.Evaluations`
4	ملفه الشخصي (ReadSelf)، فريقه (ReadTeam: مديرو الأقسام المرتبطون به)، البحث المختصر (Lookup)، قراءة المستندات	—	الموظفون `Hr.Employee`
5	إنشاء، معالجة، تحويل، عرض	—	المطالعات `Hr.Memo`
2	إدارة قوالب الدوام وعرضها (مع مدير الموارد)	—	الدوام `Hr.WorkShift`
1	قراءة السجل (مع المدير التنفيذي)	—	سجل التدقيق `Hr.AuditLog`
3	الإقرار بالاستلام، عرض عهدته	—	العهد `Hr.Custody`
3	إنشاء بلاغ وعرض بلاغاته	—	البلاغات `Hr.Incident`
2	قراءة الإشعارات وتسجيل الجهاز	—	الإشعارات `Hr.Notification`
1	إدارة مفوضه البديل	—	التفويض `Hr.Delegation`

العدد	صلاحيات مشتركة مع أدوار أخرى	صلاحيات حصرية لمسؤول النظام	الوحدة
4	التعاميم (Read)، العطل (View)، الأقسام (Lookup)، أصناف المخزن (Lookup)	—	عامة
69	**54**	**15**	**المجموع**

ما لا يملكه مسؤول النظام: أي صلاحية في الشكاوى (`Hr.Complaints`)، أو المالية (`Hr.Finance`)، أو العقود، أو الإنذارات، أو كتب الشكر، أو المخزن (عدا البحث)، أو التقارير. ولا ينشئ حسابات (`UserAccount.Create`) ولا يعيد ضبط كلمات السر، ولا يدير الأقسام أو ملفات الموظفين أو العطل.

مقارنة بالأدوار الأخرى

مسؤول النظام ثالث أكثر الأدوار صلاحيات (69)، بعد مدير الموارد (111) ومدير القسم (74)، لكن صلاحياته تشغيلية لا تمس البيانات الحساسة.

الدور	عدد الصلاحيات	حصرية للدور	التحقق بخطوتين	عدد الحاملين (حسب قيود الكود)
مدير الموارد البشرية `hrManager`	111	30	إلزامي	واحد فقط
مدير القسم `departmentManager`	74	11	—	متعدد
مسؤول النظام `systemAdmin`	**69**	**15**	**إلزامي**	**متعدد**
المدير التنفيذي `executiveDirector`	56	3	إلزامي	واحد فقط
الموظف `employee`	46	8	—	متعدد
المحاسب `accountant`	39	11	إلزامي	—
مسؤول المخزن `storeOfficer`	36	10	—	متعدد
المراجع `reviewer`	26	1	—	—

تقسيم الصلاحيات الحساسة بين مسؤول النظام وغيره:

- إنشاء الحسابات: مدير الموارد فقط.

- إعادة ضبط كلمة السر: مدير الموارد والمدير التنفيذي، وليس مسؤول النظام.
- إعادة ضبط التحقق بخطوتين: مسؤول النظام والمدير التنفيذي.
- تعيين الأدوار: مدير الموارد ومسؤول النظام والمدير التنفيذي، لكن أي تغيير يمس دور مدير الموارد أو المدير التنفيذي يحتاج المدير التنفيذي.
- تعديل الأدوار وصلاحياتها: مسؤول النظام وحده، ضمن الصلاحيات غير المحمية.
- سجل التدقيق: مسؤول النظام والمدير التنفيذي.

في مصفوفة الموافقات، مسؤول النظام هو المعتمد الأول لطلبات مديري الأقسام (ثم الموارد البشرية)، وطلباته هو تذهب إلى المدير التنفيذي.

صفحات التطبيق التي يراها

تظهر كل صفحة في القائمة الجانبية (`frontend/lib/app/shell.dart`) فقط إذا كان المستخدم يملك صلاحيتها. حساب `sysadmin` يحمل دوري `systemAdmin` و `employee` ، فيرى 11 صفحة إدارية إضافة إلى صفحات الموظف.

صفحات قسم الإدارة

الصفحة	المسار	ماذا يفعل فيها
الأدوار والصلاحيات	`/roles`	ينشئ أدوارًا مخصصة ويعدل أسماءها، ويحذف المخصص الخالي من المستخدمين، ويفعّل أو يلغي صلاحيات كل دور. الصلاحيات المحمية لا تظهر
الحسابات	`/accounts`	يبحث في الحسابات ويرى حالتها، ويعدل الأدوار، ويعيد ضبط التحقق بخطوتين، ويعدل الصلاحيات المباشرة. لا يرى زر إعادة تعيين كلمة السر ولا زر ملف الموظف
أجهزة البصمة	`/devices`	يسجل الأجهزة ويرى آخر اتصال، ويصدر مفتاحًا جديدًا (يبطل القديم فورًا)، ويربط مستخدمي الجهاز بالموظفين
إعدادات الحضور	`/attendance-settings`	يحدد طريقة الحضور (بصمة أو الاثنان، وGPS معطل حاليًا) والمنطقة الزمنية للشركة
قوالب الدوام	`/shifts`	ينشئ القوالب ويعدلها: النوع، دقائق السماح (0–240)، العمل الإضافي، طول الدورة، أيام العمل. يشاركه مدير الموارد
أنواع الإجازات	`/leave-types`	يضيف أنواعًا ويحدد لكل نوع: الحد السنوي، من يستحقها، الدفع، المرفق، الخصم من السنوي، التفعيل
أنواع الطلبات	`/request-types`	ينشئ أنواعًا ويحدد وجهتها بعد الموافقة (بلا وجهة، المخزن، المحاسب)، ويفعلها أو يوقفها. وجهة الأنواع النظامية مقفلة

ماذا يفعل فيها	المسار	الصفحة
يدير المعايير والسلم اللفظي (ضعيف إلى ممتاز). التغيير يسري من الدورة التالية	`/evaluation-admin`	معايير التقييم
خمس بطاقات: التذكيرات والتصعيد، مهل الشكاوى (دون رؤية المحتوى)، الإجازة الزمنية، تنبيهات العقود، معتمد الرواتب	`/system-settings`	إعدادات النظام
يعرض العمليات مع فلترة حسب الإجراء والنتيجة ونوع الكيان	`/audit-log`	سجل التدقيق
يعرض مديري الأقسام المرتبطين به	`/team`	فريقي

الصفحات الشخصية

- الرئيسية، الملف الشخصي، الإشعارات.
- البريد الوارد: يوافق فيه على طلبات مديري الأقسام أو يرفضها.
- طلباتي، إجازاتي، حضوري، المطالعات، بلاغات الأعطال، التعاميم، العطل، التفويض، عهدتي.
- من دور الموظف فقط (ما يخصه هو): الإنذارات، كتب الشكر، التقييمات، العقود، قسائم الراتب، وتقديم شكواه الشخصية.

صفحات لا تظهر له

الموظفون، الأقسام، أرصدة الإجازات، حضور الموظفين، استيراد الحضور، معالجو الشكاوى، المخزن، المالية، التقارير الشهرية، التقارير.

ملاحظات أمنية وتوصيات

الحمايات الأساسية مطبقة، لكن يوجد مسار تصعيد واحد مهم: مسؤول النظام يستطيع تعديل صلاحيات دوره هو.

الحمايات المطبقة في الكود

- لا يغير أدواره (`CannotChangeOwnRoles`) ولا صلاحياته المباشرة كمستخدم (`CannotChangeOwnPermissions`).
- لا يُزال آخر مسؤول نظام نشط (`LastSystemAdminCannotBeRemoved`).
- لا يمس دور مدير الموارد أو المدير التنفيذي (`ProtectedRoleChangeRequiresApproval`)، ولا يجمع المحاسب مع مدير القسم أو مسؤول المخزن.
- لا يمنح `Hr.Identity.*` أو الشكاوى أو المالية من الشاشة، ولا يحذف الأدوار الثابتة أو دورًا فيه مستخدمون.
- الشكاوى محمية أيضًا بـ `ComplaintAccessPolicy` ، فلا يراها حتى لو حمل دورًا آخر.

ثغرات وتوصيات

#	الملاحظة	الأثر	التوصية
1	`RoleAppService.UpdatePermissionsAsync` لا يمنع تعديل دور يحمله المستخدم الحالي	يستطيع إضافة صلاحيات غير محمية إلى دور `systemAdmin` نفسه، مثل `Hr.Employee.Read` و`Hr.Contract.Read` و`Hr.Warning.ReadAll` و`Hr.Leave.Balance.Adjust`	رفض تعديل صلاحيات أي دور يحمله المنفذ، أو حماية دور `systemAdmin` نفسه
2	قائمة `ProtectedPermissions` لا تشمل العقود والإنذارات (عدا `Read`) وكتب الشكر وملفات الموظفين	يمكن منحها لأي دور من الشاشة	مراجعة القائمة مع المالك، وإضافة `Hr.Warning.ReadAll` على الأقل
3	مسؤولا نظام يستطيع كل منهما منح الآخر صلاحيات مباشرة	تجاوز قاعدة "لا يعدل صلاحياته" بالتعاون	إشعار المدير التنفيذي بكل تغيير في الصلاحيات
4	مسؤول النظام يقرأ سجل التدقيق الذي يراقبه	الوثيقة تعد السجل أداة رقابة عليه	التأكد من أنه لا يستطيع تعديل السجل أو حذفه
5	يملك `ResetMfa`	قد يعيد ضبط التحقق بخطوتين لمدير الموارد أو المحاسب	قصرها على المدير التنفيذي للحسابات الحساسة، كما في إعادة ضبط كلمة السر

ملاحظة: البندان 4 و5 لم أراجع كودهما بالتفصيل، ويحتاجان تحققًا في `MfaAppService` وخدمة سجل التدقيق.

المصادر

- `src/HR_Mangment2.Domain.Shared/Permissions/HrPermissions.cs`
- `src/HR_Mangment2.Domain.Shared/Identity/HrRoles.cs`
- `src/HR_Mangment2.Domain/Identity/HrTenantBootstrapper.cs` و`AccountAccessEvaluator.cs`
- `src/HR_Mangment2.Application/Identity/`: `ProtectedPermissions.cs`، `PermissionGrantService.cs`، `RoleAppService.cs`، `UserAccountAppService.cs`، `AccountProvisioner.cs`
- `متطلبات_و تصميم_النظام.md`: الأقسام 3 و4 و5.18 وتنبيهات ABP والمخاطر